

建立良性工控安全生态环境

演讲人：郭 森

职务：中国华能集团公司信息中心

技术处 处长

日期：2014年9月24日



中国互联网安全大会



360互联网安全中心

China Internet Security Conference 2014

2014中国互联网安全大会

内容摘要

- 工控系统安全问题和现状
- 工控系统安全各方在行动
- 建立良性工控安全生态环境

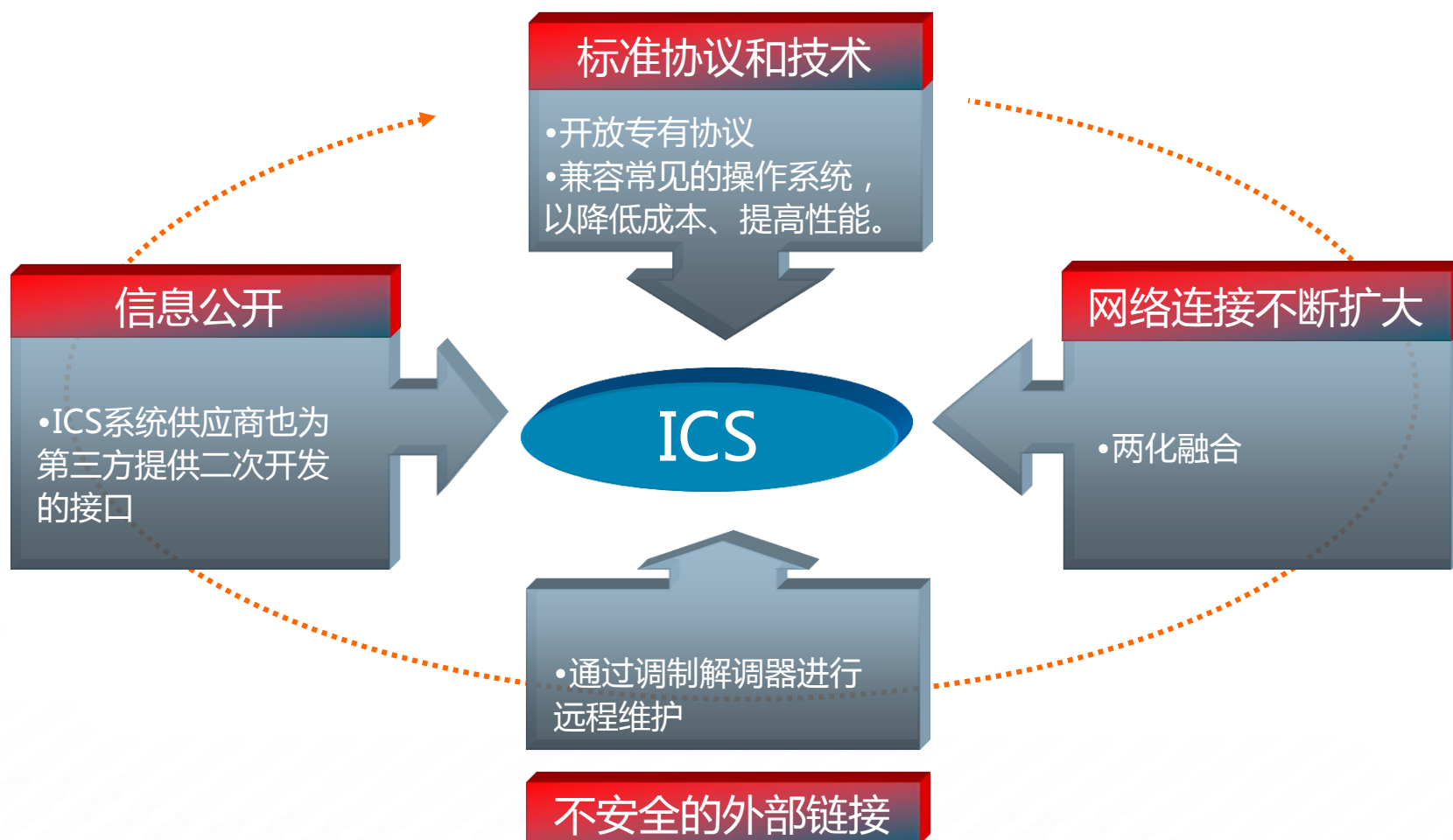
内容摘要

- 工控系统安全问题和现状
- 工控系统安全各方在行动
- 建立良性工控安全生态环境

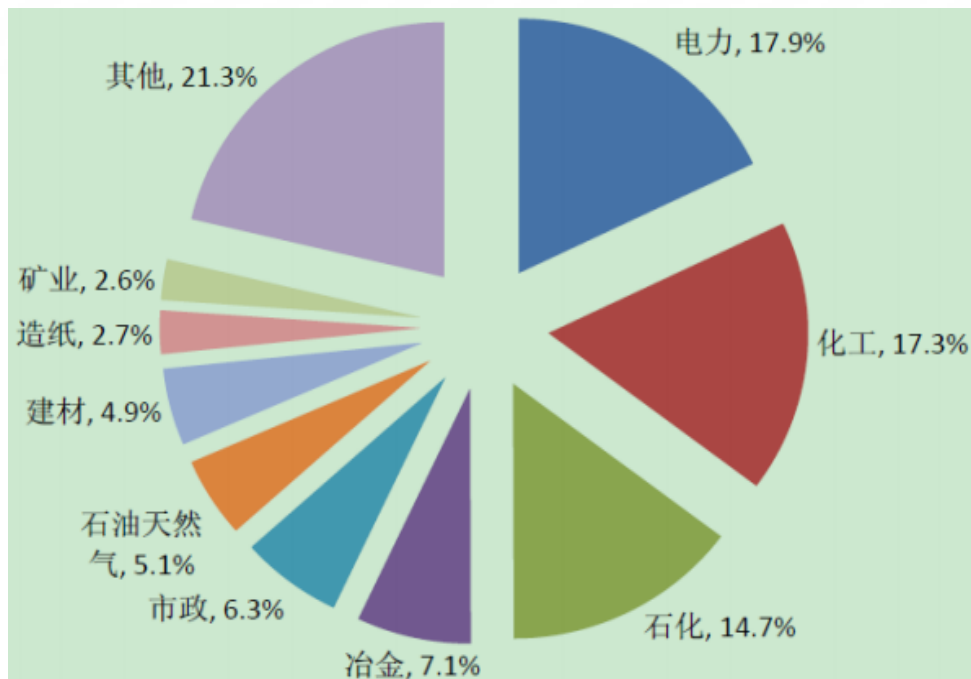
The logo for the International Scientific Conference (ISC) 2014. It features the letters "ISC" in a large, bold, black sans-serif font, with "2014" in a smaller, bold, black sans-serif font directly below it. The text is centered within a circular border composed of several colored segments in yellow, orange, red, and green.

工控系统安全问题和现状

导致工业控制系统脆弱性的主要原因



工控系统安全问题和现状



长期垄断全世界流程工业
集散控制系统 (DCS)
主要有四家公司

霍尼韦尔	Honeywell	美国
横河	Yokogawa	日本
艾默生	Emerson	美国
西门子	Siemens	德国

1995年之前完全依赖进口
2007年之前大型系统完全依赖进口

具体安全策略不一，行业涉及范围广



工控系统安全问题和现状



❖ 工业控制系统（ICS）是多种类型控制系统的总称，包括：

- 监控与数据采集（SCADA）
- 分布式控制系统（DCS）
- 过程控制系统（PCS）
- 可编程逻辑控制器（PLC）
- 应急停车系统（ESD）
- 安全仪表系统（SIS）
- 其他自动化控制系统



工控系统安全问题和现状



- ❖ 工控系统在能源、交通、水利、城市公用设施行业等国家关键基础设施发挥着“大脑”和“神经中枢”的作用，是保障基础设施安全稳定和高效运行的核心装备和技术

IT的需求

- 高吞吐量
- 标准统一的通信协议
- 设备部署在本地，易于访问
- 设备生命周期为3-5年

ICS的需求

- 实时通信
- 不允许重启
- 人和控制过程安全
- 加入安全后不影响控制流程
- 通信协议多种多样
- 设备不易访问
- 设备生命周期为15-20年

工控系统安全问题和现状



工业控制网络：超50万装置易受互联网攻击

[北极星电力信息化网](#)

2013-1-10 10:39:58

[我要投稿](#)

关键词：[SCADA](#) [控制系统](#) [PLC](#)

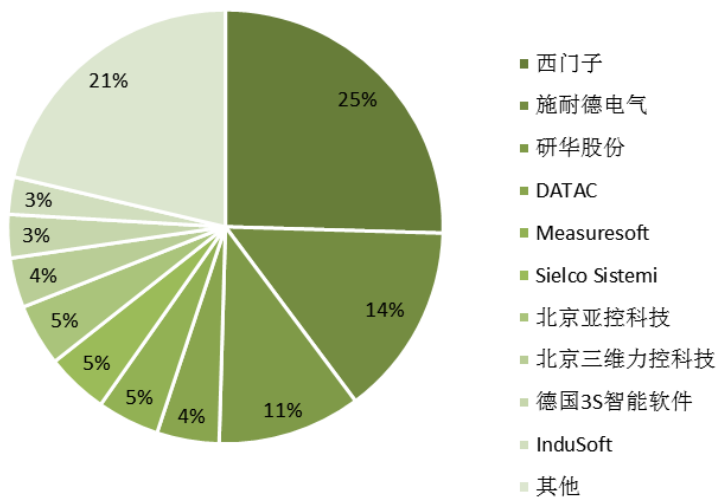
[北极星电力软件网讯](#)：网络安全研究人员发现超过50万直接连接互联网的控制装置可能被利用攻击自身及其[控制系统](#)。匿名研究人员向美国工业控制系统网络紧急响应小组（ICS-CERT）报告了其研究结果。

研究人员发现，可能易受攻击的系统使用Shodan搜索引擎和搜索控制系统相关的术语，如[SCADA](#)（监控和数据采集）。研究人员担心，网络攻击者可能以相似方式利用搜索引擎作为一种快捷方式寻找易受攻击的控制系统，从而威胁或攻击关键基础设施。

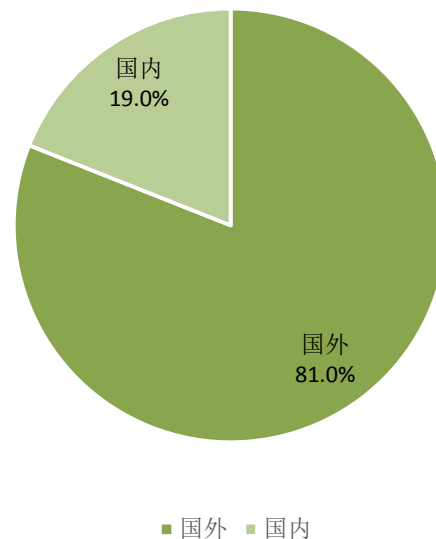
在最近一次警报中，ICS-CERT说，它正与研究人员和行业伙伴合作通知确定IP地址的主人。但它也建议控制系统主人和所有者审核自己的系统，保证使用强大的身份验证和登录系统以及与其他防御措施。

ICS-CERT还建议，控制系统所有者应使用如Shodan或Eriipp等搜索引擎审核自己的网络和设备以定位可能遭到破坏的互联网连接控制系统设备。如果发现潜在的易受攻击的设备，ICS-CERT建议尽快从直接或不安全的网络链接中删除这些设备。

工控系统安全问题和现状



公开漏洞所涉及的主要ICS系统厂商



公开漏洞相关厂商的地域分布

说明：

各厂商产品的漏洞数量不仅与产品自身的安全性有关，也和厂商的产品种类、产品的复杂度以及受研究者关注的程度等多种因素有关。

所以，我们并不能简单地认为，公开漏洞数量越多的厂商，其产品就越不安全

工控系统安全问题和现状



国内电力系统中也已有漏洞出现，潜在的威胁很大

漏洞回应

厂商回应：

危害等级：高

漏洞Rank：17

确认时间：2012-05-11

厂商回复：

在lee同学的大力帮助下，完成漏洞的确认和复现过程。

同时，将对某厂商产品进行进一步排查。

在周一会协调国家电力监督管理委员会信息中心处置。

对漏洞评分如下：

CVSS：(AV:R/AC:L/Au:NR/C:C/A:P/I:P/B:N) score:8.97 (最高10分，高危)

即：远程攻击、攻击难度低、不需要用户认证，对机密性造成完全影响，对可用性、完整性造成部分影响(涉及生产系统，暂未进一步测试，仅根据当前测试环境评估)。

工控系统安全问题和现状

- 工控协议的安全性
 - 协议自身固有的安全问题
 - 工控协议自身特点所造成的固有安全问题
 - 工控系统相关的通用协议（比如：TCP/IP）的固有安全问题
 - 系统开发过程中引入的协议安全问题
 - 比如：协议编程实现过程中引入的软件缺陷

工控系统安全问题和现状



对比项		工业控制系统（ICS）	传统IT信息系统
安全威胁	威胁来源	以组织为主	个体、群体、组织
	攻击方法	- 攻击目的性强的高级持续性威胁（APT：StuxNet、Duqu等 - 采用有组织的多攻击协同模式	- 常用攻击方式：拒绝服务、病毒、恶意代码、非授权访问、欺骗等 - 也有一些组织采用APT的攻击模式攻击重要信息系统
安全防护	系统安全	- 关注ICS系统及其设备专用操作系统的漏洞、配置缺陷等问题 - 当前系统防护能力不足：系统补丁管理困难、安全机制升级困难	- 关注通用操作系统的漏洞、配置缺陷及资源非授权访问等问题 - 系统级防护能力较强（防病毒、补丁管理、配置核查、外设管控等系统级安全手段丰富）
	网络安全	- 重点关注专有通信协议或通信规约的安全性及其实时、安全的传输能力 - ICS系统缺乏统一的数据通信协议标准，通信协议（规范）的种类繁多 - 专有通信协议及规约通常只强调通信的实时性及可用性，对安全性考虑不足：如缺少足够强度的认证、加密与授权等 - 通常需要与互联网进行物理隔离	- 主要是关注TCP/IP协议簇的数据传输安全、拒绝服务、应用层安全等，一般对数据传输的实时性要求不高 - 安全技术、产品、方案相对成熟，安全防护能力强 - 一般不要求与互联网物理隔离
	数据安全	重点关注ICS设备的状态、控制命令等信息在传输、处理及存储中的安全性	服务器中存储数据的安全存储及授权使用

工控系统安全问题和现状



对比项		工业控制系统 (ICS)	传统IT信息系统
安全管理	身份管理	● 系统用户身份认证及授权管理相对简单，甚至没有 ● 部分控制设备是通过硬件实现的，难以对密码进行周期性修改	● 认证、授权机制比较成熟、完善 ● 用户身份管理功能用软件实现，可方便对密码进行周期性修改
	补丁管理	ICS系统补丁管理困难、漏洞难以及时处理 ● ICS系统补丁兼容性差、发布周期长；系统可用性与业务连续性的硬性要求，使得ICS系统管理员绝不会轻易安装非ICS设备制造商指定的升级补丁 ● 使用周期长、相对陈旧的系统，也可能因无法继续得到厂商的支持，而造成系统漏洞无法及时打补丁	● 传统IT信息系统的漏洞与补丁管理系统（或工具）比较成熟，漏洞一般可以及时地得到处理
	行为管理	● ICS需严格防止系统误操作与蓄意破坏 ● 通常缺乏日志审计及配置变更管理 ● 存在部分ICS系统不具备审计功能；或者虽有日志审计功能，但系统的性能要求决定了它不能开启审计功能	● 一般有比较完善的信息系统操作及网络行为的审计机制
	应急响应	● 需要保障ICS系统业务连续性的应急响应计划，强调快速响应	● 应急响应计划可选

工控系统安全问题和现状

- 分析了MODBUS、PROFIBUS、DNP3、ICCP等多种协议的安全性进行详细分析,下面以MODBUS为例进行简单分析

根源	安全问题举例
缺乏认证	仅需要使用一个合法的Modbus地址和合法的功能码即可以建立一个Modbus会话
缺乏授权	没有基于脚色的访问控制机制，任意用户可以执行任意的功能
缺乏加密	地址和命令明文传输，可以很容易地捕获和解析

MODBUS协议相关的几个典型安全问题

功能码滥用是导致MODBUS协议工作异常的一个主要因素

序号	异常行为描述
1	强制从站进入只听模式（08-04）
2	重启通讯会话（08-01）
3	重置诊断信息（例如计数器或诊断寄存器等）（08-0A）
4	请求从站标志信息（43-14）
5	请求从站附加信息（17）
6	不合法的报文长度（2个字节表示长度），潜在拒绝服务攻击
7	非Modbus协议运行在TCP的502端口
8	从设备忙异常代码延迟（异常码06），潜在拒绝服务攻击
9	确认异常代码延迟（异常码05），潜在拒绝服务攻击
10	不正确的报文长度（最大253），潜在拒绝服务攻击
11	配置扫描（例如定义的点列及其值）（30秒内5个异常码02）
12	可用功能码扫描（60秒内3个异常码01）
13	修改分隔符（08-03）
14	周期较短（实际阈值待定）的无意义命令，暴力拒绝服务
15	广播性质的报文或一个主站向多个从站的请求
16	包含在异常协议数据单元中的信息

内容摘要

- 工控系统安全问题和现状
- 工控系统安全，各方在行动
- 建立良性工控安全生态环境

工控系统安全，各方在行动



工控系统安全目标

	进不来	拿不走	看不到	改不了	走不脱
管理体系	访问控制 人力资源	资产管理 系统建设管理	数据安全 通信与操作	通行于操作管理 系统获取、开发、 备份	符合性 安全事件管理 IT内控
技术体系	物理和环境安全 AV, FW, 机房 网络准入、终端 安全	权限控制 内容过滤	PKI、CA证书、加 密	安全认证、数字签 名、电子印章	SOC, IDS, 审计产品
运维体系	DC进出审批 账户审批流	安全运维 变更管理流	权限审批流 配置管理流	风险控制流程 问题和事件管理流	安全事件发现报 告流程

组织、测量、考核评价、应急、宣传教育

工控系统安全，各方在行动



中华人民共和国中央人民政府

The Central People's Government of the People's Republic of China

www.GOV.cn

网站首页 | 今日中国 | 中国概况 | 法律法规 | 公文公报 | 政务

当前位置： 首页 >> 公文公报 >> 国务院文件 >> 国务院文件

中央政府门户网站 www.gov.cn 2012年07月17日

【字体：大 中 小】 打印本页

国务院关于大力推进信息化发展和切实保障信息安全的若干意见

国发〔2012〕23号

各省、自治区、直辖市人民政府，国务院各部委、各直属机构：

大力推进信息化发展和切实保障信息安全，对促进经济发展和改善民生、维护国家安全具有重大意义。近年来，党中央、国务院决策部署，加快推进信息化建设，建立了经济社会发展。当前，世界各国信息化快速发展，优化配置和发展模式创新，互联网对政治、经济、文化、信息获取、利用和控制的国际竞争日趋激烈，保障我国信息化建设和信息安全保障仍存在一些亟待解决的问题。与发达国家的差距有所拉大，政务信息共享和业务

国务院副总理马凯视察工业控制安全技术国家工程实验室

中国机经网 发布时间：2013-09-27 11:09:58 来源：中控

关键词： [马凯](#) [视察](#) [工业控制](#) [安全技术](#) [国家工程实验室](#)

内容摘要：9月4日，中共中央政治局委员、国务院副总理马凯一行，在浙江大学党委书记金德水、校长林建华陪同下，莅临浙江大学视察工业控制安全技术国家工程实验室，浙江大学副校长、工业控制安全技术国家工程实验室主任褚健教授向马凯汇报了工业控制安全方面的最新科研成果。

9月4日，中共中央政治局委员、国务院副总理马凯一行，在浙江大学党委书记金德水、校长林建华陪同下，莅临浙江大学视察工业控制安全技术国家工程实验室，浙江大学副校长、工业控制安全技术国家工程实验室主任褚健教授向马凯汇报了工业控制安全方面的最新科研成果。

马凯充分肯定了工程实验室在工业控制系统安全技术方面取得的科研成果，并对中控在控制系统国产化方面取得的成就表示了赞赏。他说：你们做了国家、民族急迫要解决的一件大事情；希望你们继续努力，再接再厉，发挥更大的作用。并嘱咐道：你们责任很重大，走的是一条工业化和信息化深度融合的路子，也是军用和民用互相结合，产、学、研互相结合的路子，这是一条非常正确的路，希望你们继续发扬，走下去。

国家领导人的来访，极大地鼓舞了研发团队的士气；大家纷纷表示，要更加积极地投入工作，为加速提升国家实力贡献更大力量。

工控系统安全，各方在行动



- 《国家发改委办公厅关于组织实施2014年国家信息安全专项有关事项的通知》
- 为了贯彻落实中央网络安全和信息化领导小组的有关要求，以及《国务院关于大力推进信息化发展和切实保障信息安全的若干意见》（国发[2012]23号）的工作部署，为加强涉及国计民生重要信息系统的网络安全保障，经商有关部门，国家发展改革委决定继续组织国家信息安全专项。

工控系统安全，各方在行动



1、民航领域

2、铁路领域

3、银行领域

4、证券领域

5、保险领域

6、工业领域

7、能源领域

8、电子政务领域

9、基础电信领域

10、互联网领域

工控系统安全，各方在行动



- 由国家能源局牵头，组织国家电网公司、中国华能集团公司、中国大唐集团公司、中国华电集团公司、中国国电集团公司等单位，围绕**生产控制系统和智能电网信息基础设施中的重大安全问题**，重点开展典型信息系统安全可控改造、边界安全防护与保障体系建设等工作，建立安全可控的生产控制系统和网络入侵检测与防范手段，形成以杜绝重大灾难性事件为底线的综合安全防护体系，制定完善信息系统安全管理、责任认定、等级保护、应急处置、互联网出口安全监管、第三方的安全维护服务等制度，制定完善能源领域网络安全相关标准规范，保障控制命令真实可信、控制数据安全传输、控制行为可审计、安全事件可追溯。

工控系统安全，各方在行动



范围	内容			结果	
围绕	开展	制定	建立	形成	保障
生产控制系统	信息系统安全可控改造	信息系统安全管理	可控的生产控制系统	杜绝重大灾难性事件	控制命令真实可信
智能电网基础设施	边界安全防护	责任认定	网络入侵检测和防范手段	综合安全防护体系	控制数据安全传输
	保障体系建设	等级保护			控制行为可审计
		应急处置			安全事件可追溯
		互联网出口安全监管			
		第三方的安全维护服务等制度			
		网络安全相关标准规范			

工控系统安全，各方在行动



工业和信息化部

工业和

各省、自治区、直辖市

工业控制系统信息安全
安全管理，经国务院

一、充分认识

数据采集与监控
等工业控制系统广泛
统信息安全出现漏洞
息化与工业化深度融
件，以各种方式与互



你的·安全频道 safe.it168.com



工控系统安全，各方在行动





公安部信息安全等级保护评估中心

MPS Information Classified Security Protection Evaluation Center

[政策标准](#) [【首页】](#) [【中心介绍】](#) [【最近要闻】](#) [【中心业务】](#) [【政策标准】](#) [【技术交流】](#)

您的位置：中心简介>>...

公安部信息安全等级保护评估中心（以下简称评估中心）成立于2003年7月23日，由国家信息安全主管部门为建立信息安全等级保护制度，构建国家信息安全保障体系，提供技术支撑机构。

评估中心的主要任务：一是按照国家信息安全等级保护的要求，依据信息安全等级保护标准，对国家管理部门在推进信息安全等级保护工作过程中的监督、检查、指导等行政执法行为提供技术支持；二是承担国家基础网络和重点信息系统的安全保护状况进行权威测评并提出改进建议；三是承担国家信息安全等级保护标准体系设计和技术支撑体系建设的任务。

评估中心自成立以来，积极参与国家信息安全等级保护管理规范制定以及信息安全等级保护标准体系设计；承担国家信息安全等级保护标准体系设计和重要技术标准的编制及宣贯；作为国家信息安全等级保护主管部门的各项信息安全检查工作，开展针对重点领域、重要行业信息系统的安全等级测评工作。到目前为止，已先后完成了上百个重要系统的信息安全等级测评。

自2009年公安部开展等级保护测评体系建设工作以来，我中心作为主要技术支撑机构的能力验证工作。2010年以来，已经顺利完成了对国家和地方等级保护协调测评机构的能力评估工作，完成了近1000多人次的等级测评师的培训工作。2010年6月23日获得公安部颁发的信息安全等级保护测评机构推荐证书[证书编号（国）001]，承担国家信息安全等级保护测评工作。这一证书标志着评估中心在等级保护测评领域多年的努力得到认可，标志着国家信息安全等级保护测评领域核心权威机构的道路上又迈出了重要的一步。

评估中心作为依照国家标准（CNAL/AC01:2005）和国家信息安全主管部门授权，获得了中国实验室国家认可委员会（CNAL）的实验室认可证书（L0653）及中国国家计量认证合格证书（L2407）。

评估中心经过6年的建设，配备了各类先进的专用检测设备和测试工具，现有

文章搜索

请输入查询条件

[清除](#) [提交](#)

成功案例

- 三峡库区地质灾害防治信息与决策支持系统安全性测评
- 广东电网公司信息系统安全评估和安全体系设计
- 全国公安信息系统公钥基础设施与授权体系应用示范工程技术监理
- 宁波卷烟厂网络与信息系统安全现状评估



#5668 P. 003/000

#5558 P. 004/004

工控系统安全问题和现状



全国信息安全标准化技术委员会

网址：www.tc260.org.cn/

TC号	260	TC名称	信息安全
SC号		SC名称	
对口组织	ISO/IEC/JTC1/SC27		
专业范围	负责组织开展国内信息安全有关的专业领域标准化工作		
所在单位	中国电子技术标准化研究院		
联系人	林宁	联系电话	010-64060375 罗锋盈： 15901234287
通讯地址	北京市1101信箱		
邮编	100007		

全国信息安全标准化技术委员会（TC260）

- 《工控系统安全管理基本要求》《工控系统信息安全分级指南》
- 《工控系统信息安全检查规范》《工控系统信息安全防护技术要求与测试评价方法》《工控系统测控终端安全要求》
- 《SCADA系统安全控制应用指南》(20100384-T-469)
- 《工控可控信息系统电力系统安全指标体系》(20120527-T-469)

机构和厂家进入工控安全领域



国家电网
STATE GRID

南瑞集团公司(国网电力科学研究院)

NARI GROUP CORPORATION · STATE GRID ELECTRIC POWER RESEARCH INSTITUTE



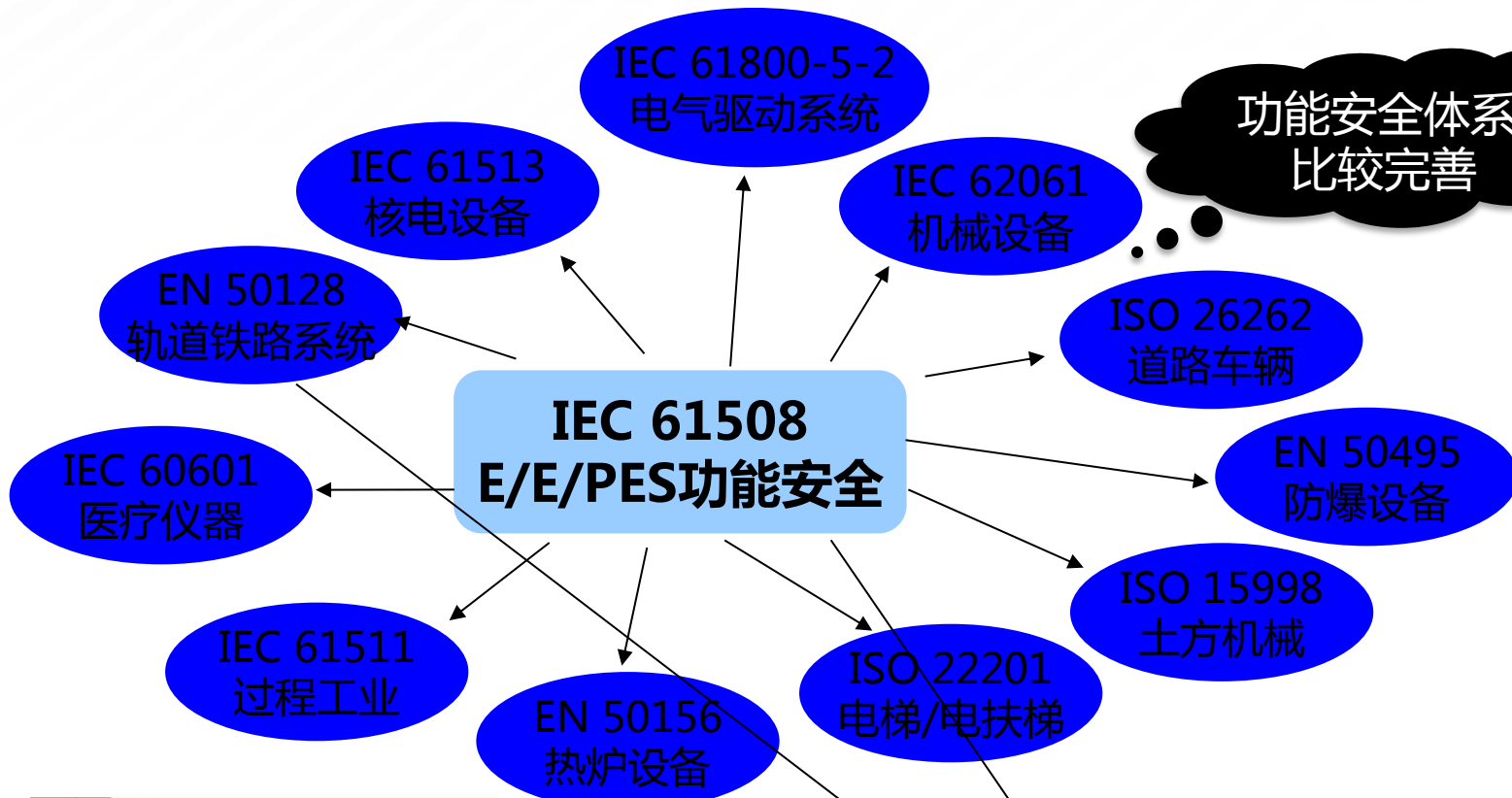
启明星辰
领航信息安全

Mydrivers.com 驱动之家

内容摘要

- 工控系统安全问题和现状
- 工控系统安全各方在行动
- 建立良性工控安全生态环境

国外功能安全标准



功能安全体系
比较完善

国内缺少
具体可操
作的安全
标准，核
心技术、
核心安全
数据、核
心评估工
具均被国
外企业和
评估机构
垄断



- ❖ 欧盟：起步于19世纪末
 - 德国：TUV莱茵、TUV南德意志
 - 英国：劳氏铁路认证

国外信息安全标准-IEC



标准名称	制定者	内容概要	特点分析
IEC 62443系列《工业过程测量、控制和自动化 网络与系统信息安全》	IEC/TC65/WG10与ISA99联合工作组	定义一个通用的、最小要求集以达到各级SALS安全保障需求。可指导工控系统集成商、产品提供商和服务提供商对他们的产品和服务进行安全性评估。	目前仅出台3份标准，主要是基础标准、策略和规程标准

国外信息安全标准-JTC1

ISO/IEC TR 27019 《基于ISO/IEC 27002的用于能源行业过程控制系统的信息安全管理指南》	ISO/IEC JTC1/SC 27	ISO/IEC TR 27019遵循了国际标准ISO/IEC 27002《信息安全控制实用规则》的框架概括了信息安全方针、信息安全组织结构、资产管理、人力资源安全、物理和环境安全、通信和操作管理、访问控制、信息系统获取开发与维护、信息安全事件管理、业务连续性管理以及符合性等11个方面的安全需求和控制实施建议。对于传统的信息安全问题，标准直接引用ISO/IEC 27002的内容；对于过程控制系统特有的信息安全问题，标准则给出了专用的安全控制实施指南	1) 27019是目前SC27唯一——一个跟工控系统有关的国际标准； 2) 其对象仅是过程控制系统（PCS），没有涉及整个工控系统甚至系统拥有者自身的信息安全管理； 3) 采用了27002的框架，内容全面、无分级控制的思想。
---	---------------------------	--	--

国外信息安全标准-NIST



标准名称	标准制定者	内容概要	特点分析
NIST SP800-82 《工业控制系统 (ICS) 安全指南》	美国标准技术研究院 (NIST)	概述了ICS和SCADA系统概述及其典型的系统拓扑;描述了ICS与IT系统之间的区别;标识了典型威胁和脆弱性以及安全事件;给出了ICS安全建设中的网络体系结构;阐述了SP 800-53中有关管理上、运行上以及技术上的安全控制措施如何在ICS和SCADA中进行应用。	1) 专门应对工控系统特有的信息安全问题而定; 2) SP 800-82本身不能单独使用, 它旨在阐述工控系统安全威胁和风险的基础上 3) 继承了53中安全控制基线要求和增强要求的思想。
NIST SP800-53 《 信息系统的组织和隐私控制 》	美国标准技术研究院 (NIST)	它提供了安全控制的层次化、结构化的安全控制措施要求, 意识和培训、认证、认可和安全评估、配置管理、持续性规划、事件响应、维护、介质保护、物理和环境保护、规划、人员安全、风险评估、系统和服务采购、系统和信息完整性这13个安全管理和运营控制族以及106个具体控制措施。	800 - 53只是作为选择最小安全控制的临时性指南

国内标准状况-TC260

- ❖ 《工业控制系统安全管理基本要求》
- ❖ 《工业控制系统信息安全分级指南》
- ❖ 《工控SCADA系统安全防护管理指南》
- ❖ 《安全可控信息系统（电力系统）安全指标体系》
- ❖ 《工业控制系统安全防护技术要求和测试评价方法》
- ❖ 《工业控制系统安全检查指南》
- ❖ 《工业控制系统测控终端安全要求》
- ❖ 《工业控制系统专用防火墙技术要求》

国内信息安全标准



- 全国电力系统管理及其信息交换标准化技术委员会（TC 82）是与IEC TC57对口的标准化技术委员会。
 - 《电力系统管理及其信息交换数据和通信安全》
- 全国工业过程测量和控制标准化技术委员会（TC124）对口国际IEC/TC65 “工业过程测量和控制”。
 - 《工业控制计算机系统通用规范 第2部分:工业控制计算机的安全要求》
 - 《工业控制系统信息安全 第1部分：评估规范》
 - 《工业控制系统信息安全 第2部分：验收规范》
- 全国电力监管标准化技术委员会（TC296）
 - 《电力二次系统安全防护标准》（强制）
 - 《电力信息系统安全检查规范》（强制）
 - 《电力行业信息安全水平评价指标》（推荐）

国家发改委发布2014第14号令



《电力监控系统安全防护规定》

- 第一章 总则
- 第二章 技术管理
- 第三章 安全管理
- 第四章 保密管理
- 第五章 监督管理
- 第六章 附 则

国家发改委发布2014第14号令



- 1 . 《电力监控系统安全防护总体方案》
- 2 . 《省级以上调度中心监控系统安全防护方案》
- 3 . 《地、县级调度中心监控系统安全防护方案》
- 4 . 《变电站监控系统安全防护方案》
- 5 . 《发电厂监控系统安全防护方案》
- 6 . 《配电监控系统安全防护方案》

《发电厂监控系统安全防护方案》



修订后

参照2012年12月印发的《风电、光伏和燃气电厂二次系统安全防护技术规定》的结构修改。

章节包括：

基本原则、安全区的划分、边界安全防护、综合安全防护、附录（各类型电厂安全分区表和防护示意图）

内容涵盖：

火电、水电、核电、风电、光伏发电、天然气发电

修订前

章节包括：

总则、安全分区、总体部署、总体要求

内容涵盖：

火电、水电

《发电厂监控系统安全防护方案》



修订后

增加了综合安全防护要求

- 1、安全加固要求（增加了对主机与网络设备的加固要求）
- 2、边界防护问题（控制大区增加了入侵检测要求）
- 3、应用安全控制（对重要业务系统登录及访问进行控制，加强安全机制）
- 4、安全审计（控制大区增加了安全审计要求）
- 5、专用安全产品管理（增加了保密要求，关闭工控产品远程链接功能）
- 6、备份与容灾（增加了异地备份要求）
- 7、恶意代码防范（增加了恶意代码防范要求）

《发电厂监控系统安全防护方案》



修订后

控制与管理大区的跨区域应用问题

- 1、SIS系统部署位置细分为一区（监测功能）、二区（优化功能）和管理信息大区（管理功能）。
- 2、明确了核电站和风电场的一些信息系统（核辐射监测系统、测风塔系统、天气预报系统等）的部署位置。

国家能源局工控产品安全检测



国家能源局

能源信息函〔2014〕35号

关于协助做好电力工控 PLC 设备 信息安全检测工作的函

中国华能集团公司办公厅：

为落实《国家能源局综合司关于开展电力工控 PLC 设备信息安全隐患排查及漏洞整改工作的通知》（国能综安全〔2013〕387 号）精神，我中心将组织开展电力工控 PLC 设备信息安全检测工作，具体检测由电力行业信息安全等级保护测评中心第一、二、四实验室共同承担，要求 7 月 20 日前完成施耐德、西门子等厂家部分 PLC 设备的信息安全检测工作。

在先期组织的电力工控 PLC 设备信息安全隐患排查和漏洞整改工作中，华能集团以高度的政治责任感和历史使命感，率先开展了电力工控 PLC 设备信息安全整改试点等工作，为消除 PLC 设备信息安全隐患、提高电力信息系统安全水平做出了积极贡献，望再接再厉，在本次检测工作中做好设备提供及测评验证等工作，为电力行业信息安全工作做出更大贡献。

联系人：王恩库

联系电话：58681853 13910802748



华北电力大学
NORTH CHINA ELECTRIC POWER UNIVERSITY



中国华电集团公司
CHINA HUADIAN CORPORATION

电力行业
信息安全
等级保护
测评中心
第一、
二、四实
验室

工控系统安全整改的误区



重技术，轻管理

重标准，轻市场

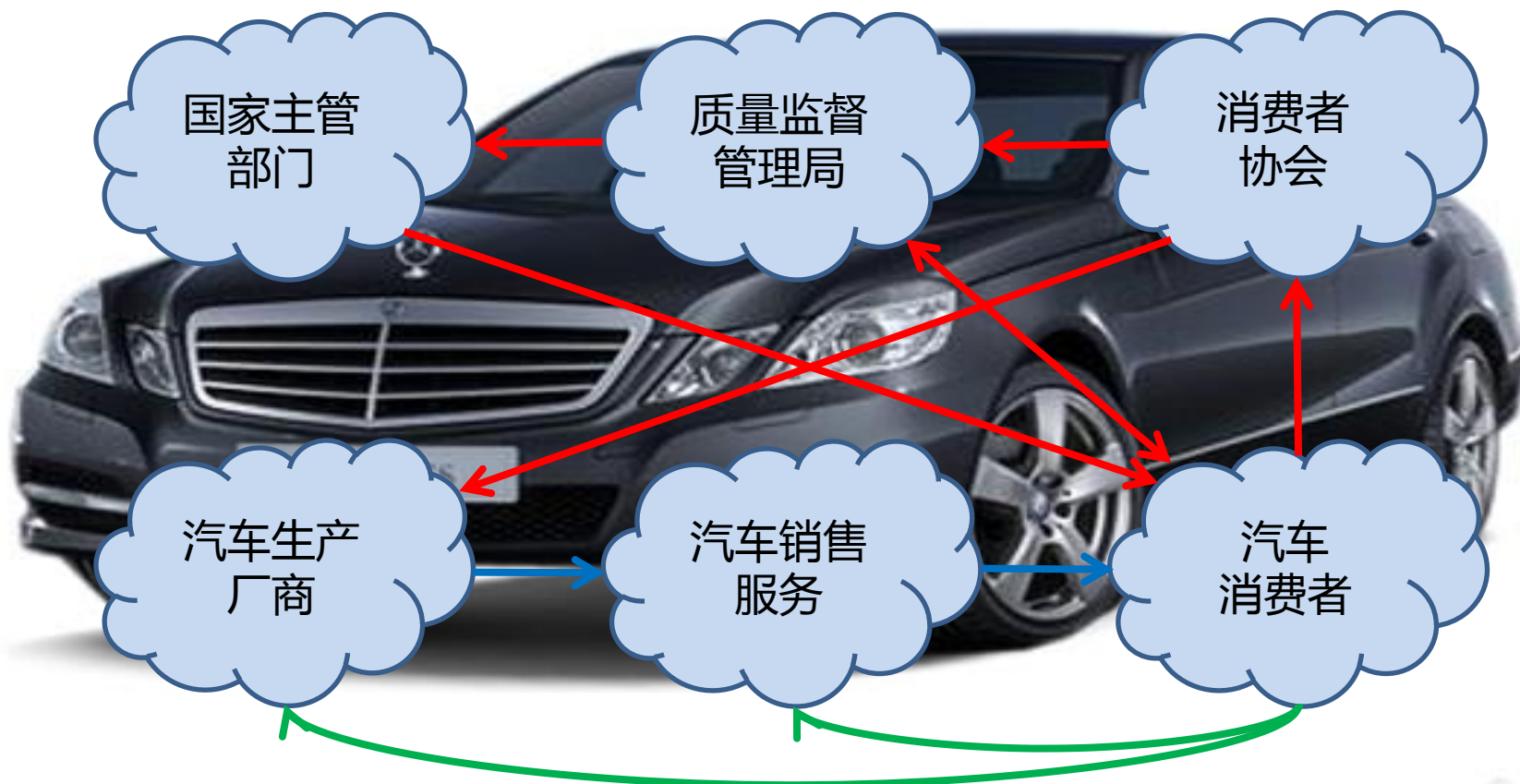
重效益，轻治理

重结果，轻过程

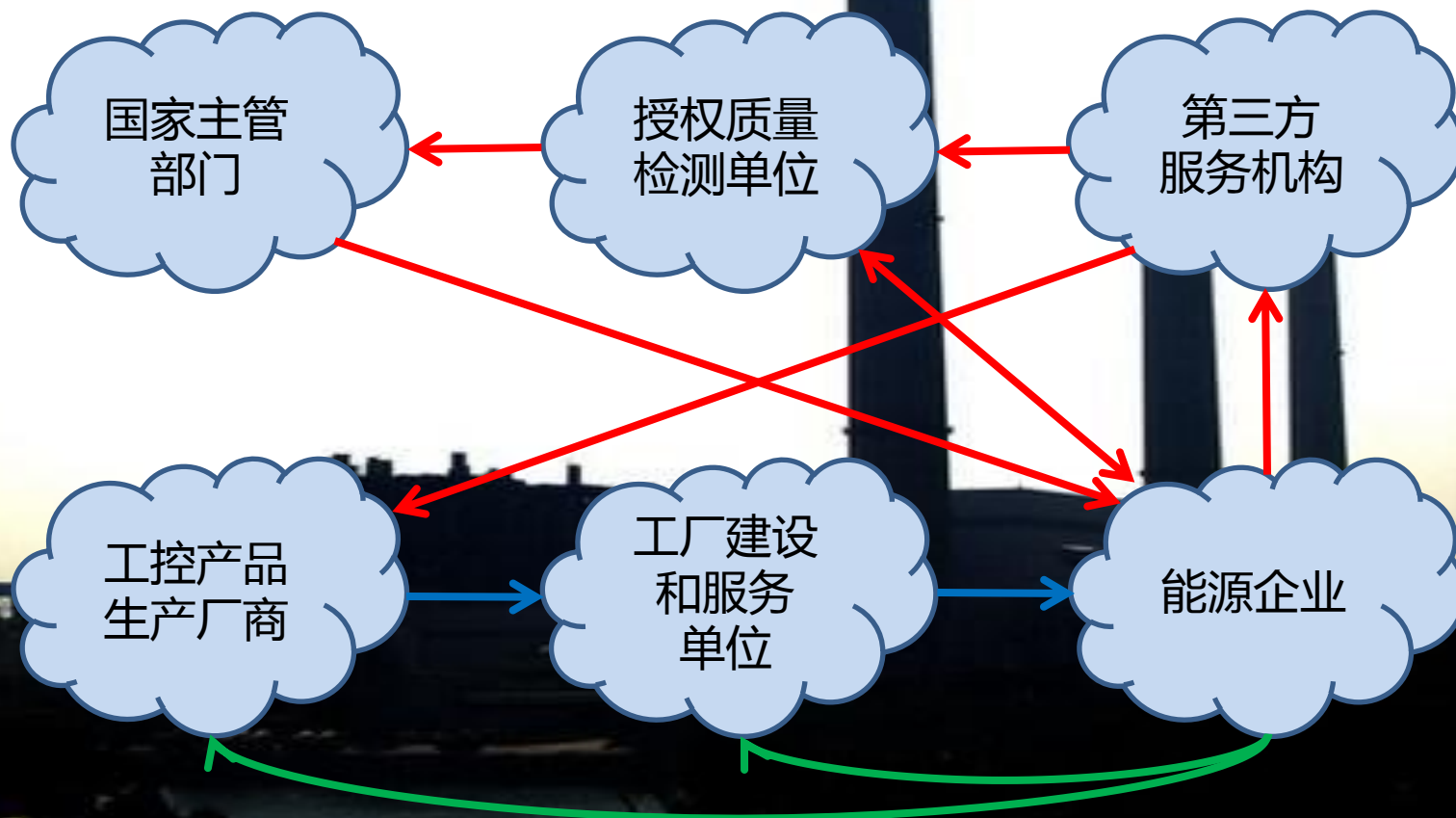
管理和
引导
并重



建立良性工控安全生态环境



建立良性工控安全生态环境

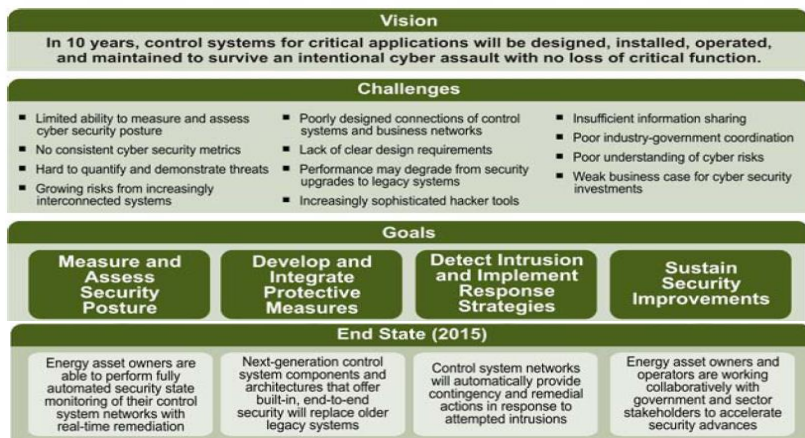


建立良性工控安全生态环境



流程 角色	发现	认定	方案	认定	实施	验收	说明
政府部门	✓					✓	
安全机构		✓		✓		✓	
第三方	✓				✓		
产品厂商			✓		✓		
能源企业					✓		
行业专家	✓					✓	

建立良性工控安全生态环境

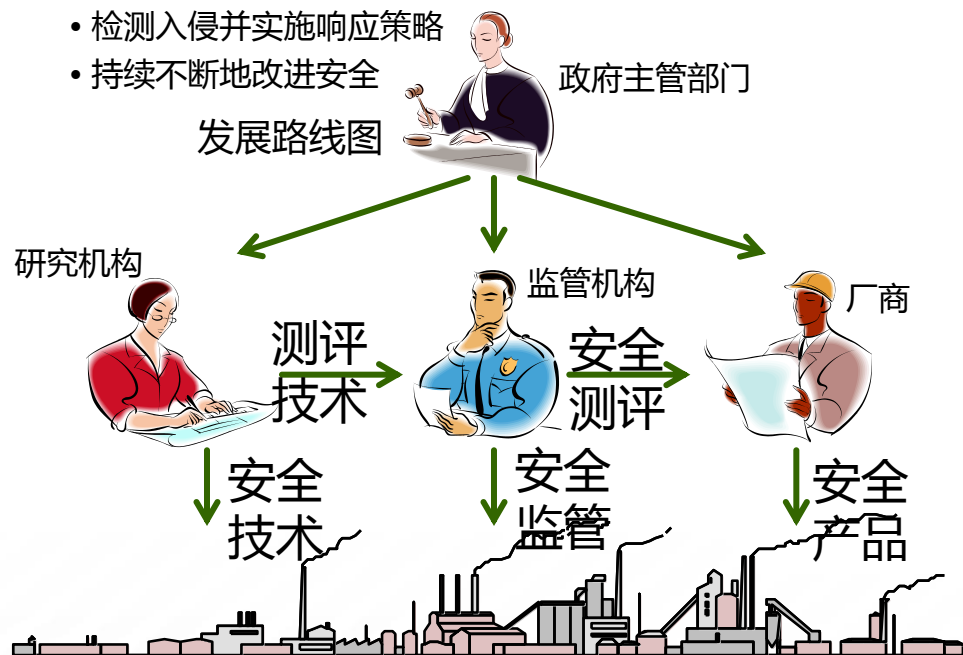


"Roadmap to Secure Control Systems in the Energy Sector"

- 10年内，涉及关键应用的控制系统被设计、运作、维护得能够经受住恶意攻击而不丧失其关键功能
- 目标
 - 测度与评估安全态势
 - 研发与集成防护措施
 - 检测入侵并实施响应策略
 - 持续不断地改进安全

多方参与、共同推进

- 政府主管机构 - 领导、组织
 - 组织各方交流，明确需求，制定规划，支持关键研发
- 监管机构 - 监督、检查
 - 逐步实现对产品的准入测评，对工业系统的安全监管
- 厂商 - 研制、提供安全产品
 - 开发并提供符合安全测评规范的产品
- 研究机构（高校） - 研制关键技术
 - 科学实验，创新研究，提供测评工具，解决技术难点
- 工业界
 - 提供需求，逐次部署安全措施，持续进行安全改进





建立良性工控安全生态环境



实行了强制标准

建立了交通规则

带来了安全风险

提高了出行效率

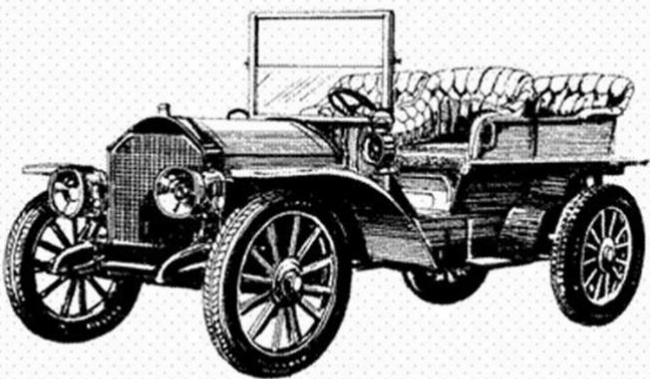
逐步变化的过程

建立良性工控安全生态环境



《汽车行业生产件与
相关服务件技术规范
(2002年)》

hshs.com



1886年1月29日，卡尔·本茨发明的世界上第一辆四轮汽车获得了“汽车制造专利权”。

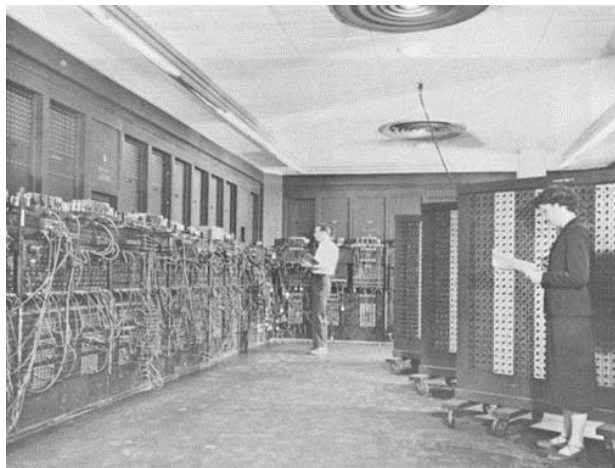
17年

世界上第一部交通法规——《驾车规则》，由美国于1903年正式颁布实施，由美国交通专家威廉·菲尔普斯·伊诺撰写的。

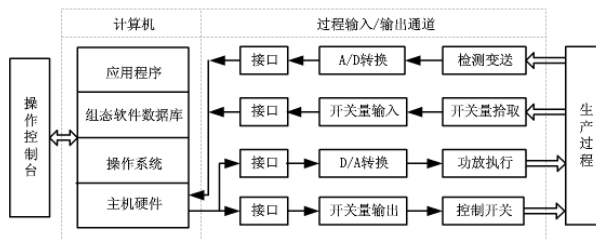
116年

为了协调国际汽车质量系统规范，由世界主要的汽车制造商协会于1996年成立了一个专门机构，称为国际汽车工作组（IATF）。

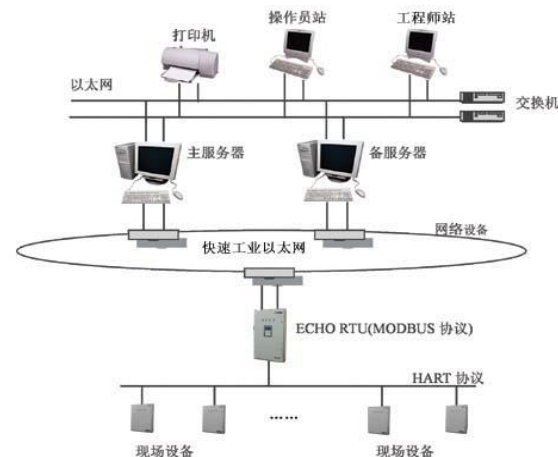
建立良性工控安全生态环境



DDC系统 { 优点: 经济、灵活性好、可靠性高。
缺点: 危险集中



DDC系统的结构框图



1946年2月14日，世界上第一台电脑ENIAC在美国宾夕法尼亚大学诞生。

60年代初，出现了由计算机完全替代模拟控制的控制器，被称为直接数字控制（DirectDigitalControl, DDC）。

1975年世界上第一套以多台微处理器共同分散控制，并通过数据通信网络实现集中管理（DistributedControlSystem, DCS）。

建立良性工控安全生态环境



真正意义上的工业控制系统在工业生产领域的应用，是从1975年才正式开始使用的。

加强能源企业的工控安全规范化管理；引导国外工控设备厂商改进安全防护措施。

国产自主可控的工业控制系统替代。

建立完整的标准并且通过国家冠标尚有时日，所以近期不可能依据标准进行操作。

建立良性工控安全生态环境



国际数据集团

专著IT技术领域

▪ 市场分析 - IDC

IDG业务分析

- 以市场分析、统计为基础
- 是一家专著“技术传媒”的公司
- 主要收入来源于“市场线索”的广告
- 与厂家交流 – 了解最新技术和动态
- 与客户交流 – 了解需求
- 根据新技术和新需求定义新市场

建立良性工控安全生态环境



Gartner®

高德纳咨询公司

Gartner业务分析

- 以深度技术研究为基础
- 主要收入来源于技术服务和咨询
- 与厂家交流 – 了解最新技术和动态
- 为客户做方案和咨询
- 根据新技术定义新市场

建立良性工控安全生态环境



www.aceee.org

- 非盈利机构；
- 机构目标：成为高科技的催化剂；
- 机构理念：
 - 帮助企业进行深层次的技术和政策分析；
 - 为决策者和高官提供咨询；
 - 成为企业、政府和其他社会团体的纽带；
 - 组织专业会议，联系行业厂家和客户；
 - 帮助和促进媒体对专业技术进行覆盖；
 - 通过出书、开会、建网站、新闻发布等手段，对企业和客户进行新技术的培育；

建立良性工控安全生态环境

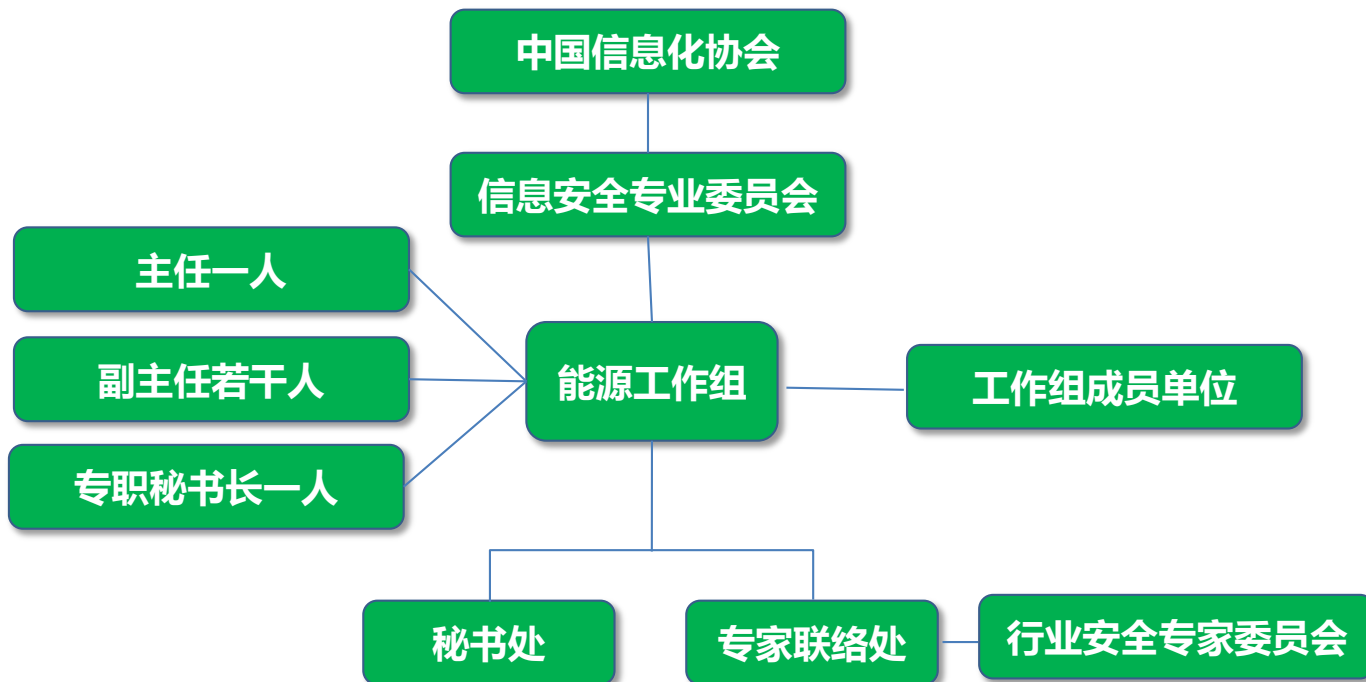
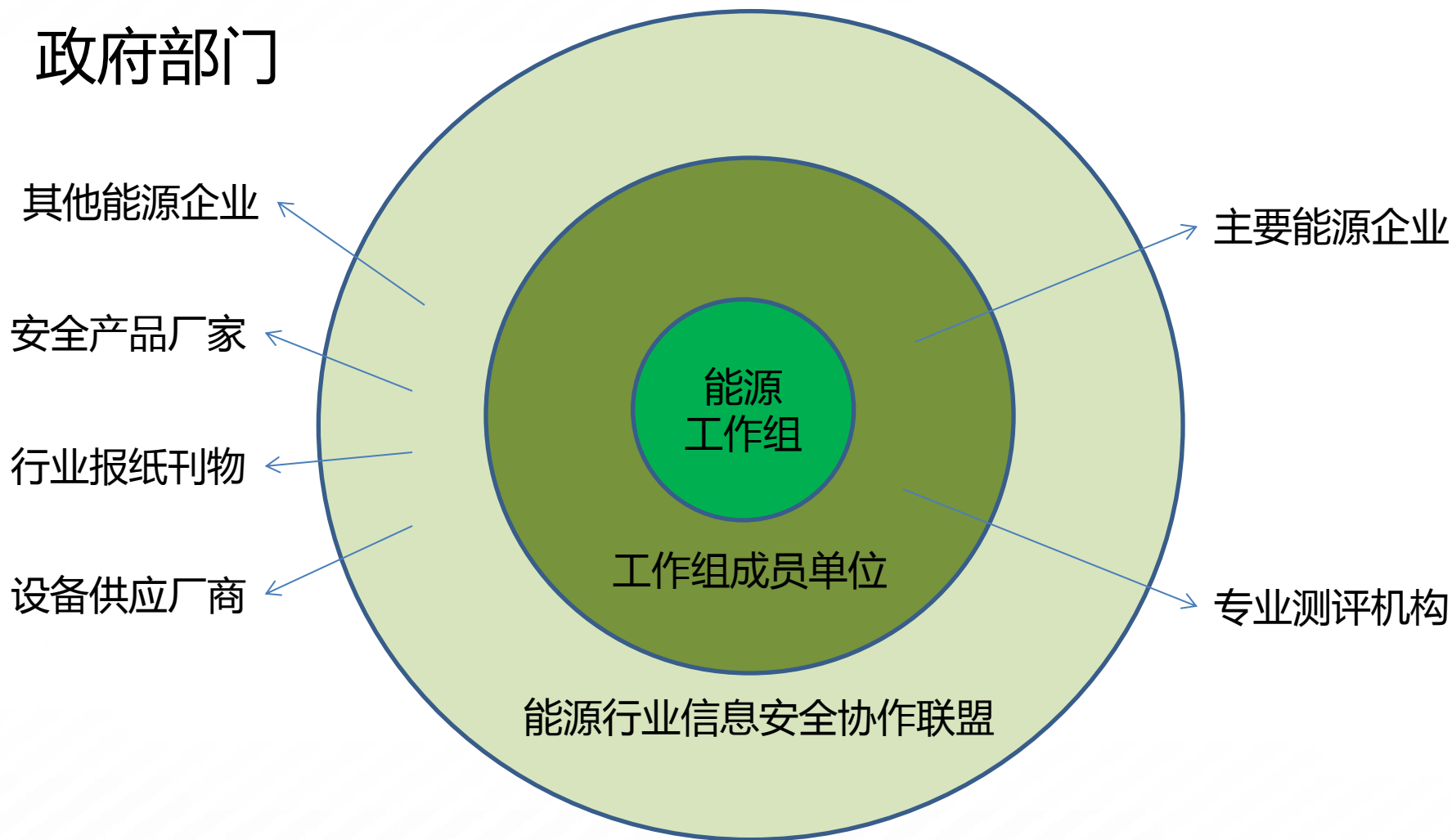


图1：能源行业办公室组织结构图

“以中国信息协会信息安全专业委员会为基础，以能源行业企业为依托”

建立良性工控安全生态环境



建立良性工控安全生态环境



配合政府部门，面向
设备生产厂商：

- 1、推动国产化进程
- 2、鼓励厂商提供安全解决方案
- 3、引导能源企业产品选型



接受能源企业委托，
提供相关支持：

- 1、技术方面
- 2、法律方面
- 3、经济利益方面

积极参与行业管理规范和安全标准的制定

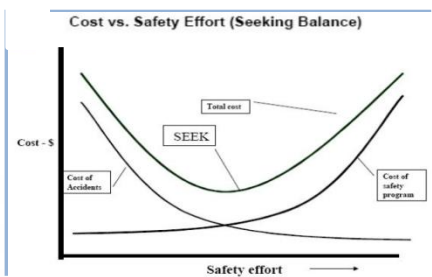
建立良性工控安全生态环境



风险=威胁 X 脆弱性



风险处置=回避+减少+转移+接受



接受残余风险的准备

建立良性工控安全生态环境



工控系统存在安全问题

十四号令加强安全防护

联合能源企业维护权益

引导行业健康发展

在良好的工控
安全生态环境
中各得其所



Thanks!